



CSRF Bank



Bối cảnh (Context)

Ngân hàng "TrustedBank" tung ra tính năng chuyển khoản 1-click rất tiện lợi. Khi bạn đang đăng nhập, bạn chỉ cần bấm vào một đường link nội bộ là tiền sẽ lập tức được chuyển cho đối tác mà không cần xác thực OTP gì thêm.

Nhân viên hỗ trợ khách hàng của ngân hàng này có thói quen bấm vào tất cả các đường link URL trong phần báo cáo khiếu nại của người dùng để kiểm tra lỗi.



Mục tiêu (Objective)

- **Nhiệm vụ:** Tạo ra một trang web bẫy. Khi nhân viên hỗ trợ (Admin) truy cập trang web này, trình duyệt của họ sẽ tự động thực hiện hành động cấp quyền hoặc chuyển tiền cho bạn mà họ không hề hay biết.
- **Vấn đề / Lỗi hổng: Cross-Site Request Forgery (CSRF).** Ngân hàng sử dụng xác thực qua Cookie nhưng lại không sử dụng Anti-CSRF Token hoặc cơ chế SameSite Cookie. Do đó, request chuyển khoản hợp lệ hoàn toàn có thể bị giả mạo và kích hoạt tự động từ một trang web của bên thứ 3.
- **Flag:** Chuyển thành công Flag hoặc tài sản từ tài khoản Admin sang tài khoản của bạn.



Gợi ý (Hints)

- Hãy kiểm tra request thực hiện hành động quan trọng, có tham số nào thay đổi ngẫu nhiên không?
- Viết một form HTML trên máy cá nhân, đặt `action` tới đường dẫn chuyển khoản của ngân hàng, và thêm đoạn JS `document.forms[0].submit()` tự động chạy.